

[doc. web n. 10109352]
Provision of November 13, 2024
Register of provisions
No. 759 of November 13, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, members, and
Counsel Fabio Mattei, Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016 (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of
personal data, hereinafter "Code"), as amended by Legislative Decree No. 101 of August 10, 2018,
containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU)
2016/679";

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the
Guarantor's Regulation No. 1/2000;

REPORTING Dr. Agostino Ghiglia;

PREMISED

1. The violation of personal data.

On November 15, 2023, the association Federprivacy (hereinafter also "the Association") notified the
Guarantor, pursuant to Article 33 of the Regulation, of a personal data breach, stating that it had
suffered, on November 13, 2023, "a cyber attack against the association's website, all email accounts
of the domain federprivacy.org, as well as all social media accounts of the association and those
personal to the president." This attack was initially attributed to "a 'defacement' operation by the
activist group called 'Alpha Team' which exfiltrated the user database and the email correspondence
from the last 10 days, subsequently deleting all email accounts used by the association's staff."
Subsequently, with the supplementary notification of December 5, 2023, the Association declared that:
following further checks, it emerged that "the email files of Federprivacy staff, including the
correspondence of the president [...], and the files of the website containing copies of 529 identity
documents that the associated professionals requesting the quality certificate of services issued by
Federprivacy pursuant to Law 4/2013 had submitted through a specific form on the association's
website, were also exfiltrated. Due to a technical configuration error, after sending the attached files to
the email address urp@federprivacy.org (via SMTP protocol with secure https connection), a copy
remained on the site";

"the email correspondence [subject to breach] concerned the last 30 days [...]";

"a total of 26,530 records of data subjects with respective names and email addresses as simple
subscribers to the association's weekly newsletter were copied and exfiltrated, of which 18,469 data
subjects (of which about 2,500 are member associates), also including professional domicile, work
contact details, VAT number or tax code, and registration number with the professional association,"
as well as the authentication credentials (username, consisting of an email address, and password)
used to access the reserved area of the Association's website;

"as a professional association pursuant to Law 4/2013, the data processed by Federprivacy exclusively
relates to the professional activity of users, who are in most cases members of professional orders
(lawyers, accountants, labor consultants, engineers, journalists, etc.) whose data are published in their
respective registers, colleges, and lists, for which it is believed that, although there has been a
significant loss of confidentiality of the data, the possible consequences and any adverse negative

effects are to be considered moderate, and significant damages of a directly economic nature are to be excluded. However, possible inconveniences, annoyances, etc. for the data subjects arising from any unlawful use of the data by third parties, such as in marketing activities, phishing, etc., cannot be excluded. Following the preliminary notification, from the investigative activities carried out on December 2, 2023, the exfiltration of the identity documents of 529 data subjects was also detected, and therefore we increased the risk for the affected data subjects and consequently proceeded immediately on December 3, 2023, to send to all 529 data subjects the communication via certified email pursuant to Article 34 of the Regulation [...], providing them with support and promptly responding to all correspondence that occurred during the same holiday day, as well as in the following days, under the direct supervision of the Data Protection Officer”;

“these are mainly common personal data relating to professionals and of a non-sensitive nature pursuant to Article 9 of the GDPR. Even regarding the exfiltration of the 529 copies of identity documents, it may potentially concern the identity theft of the data subjects, but does not present a high risk for the rights and freedoms of natural persons”;

“after restoring the functionalities of the website, and having conducted a thorough assessment using the company OneFirewall Alliance LTD [...] specialized in the field of cybersecurity, it has been...

****Procedure to further implement security measures****

by activating the Cloudflare service for protection against DDoS attacks and other threats, also enabling access to the Aruba Business control panel exclusively through a proxy server [OMISSIS] [...] Before bringing the site back online, all user accounts were cautiously blocked to prevent unauthorized individuals from accessing the reserved area of the site, and a communication was sent to the users with the necessary information to regain access.”; “By correctly configuring the site, measures were taken to prevent the storage of identity documents and other attachments sent via forms to the email address urp@federprivacy.org.” It emerged, therefore, that the attack resulted in the exfiltration (and subsequent dissemination online) of personal data of several thousand individuals, some of whom submitted reports or complaints to the Authority.

****2. The investigative activity.****

Given the high number of affected individuals and the nature of the personal data subject to violation, the Authority deemed it necessary to conduct further investigations to verify compliance with the provisions regarding the protection of personal data, with particular reference to the obligations concerning personal data breaches (Articles 33 and 34 of the Regulation) and data processing security (Article 32 of the Regulation), in relation to the technical and organizational measures in place at the time the violation occurred, those adopted to remedy it and to mitigate possible negative effects on the affected individuals, as well as those being adopted to prevent similar future violations. Specifically, considering the absence, within the notifications sent by the Association, of sufficient elements for a complete assessment of the case by the Authority, further investigative elements were acquired through two requests for information addressed to Federprivacy (notes dated January 29 and February 16, 2024), to which the Association responded (notes dated February 11 and 19, 2024). Subsequently, in March 2024, the Association provided information regarding further initiatives taken following the personal data breach.

In a note received on February 11, 2024, Federprivacy, in response to the invitation made by the Office on January 29, 2024, to provide observations useful for evaluating the profiles of personal data protection, specified that “out of a total of 26,530 individuals involved in the data breach, 18,469 of them have an account to access the reserved area with related credentials (username and password), while the other 8,061 are merely subscribers to the weekly newsletter and therefore do not have any account on the Association's website” – it was represented that: “considering that, a few days after the breach, hackers published in a hacking forum the database of our users with passwords in clear text, we believe that this was likely possible because they had direct access to the server of our website at the Aruba Business provider, allowing them to download the database with passwords encrypted via hash, but managing to reconstruct the strings related to them using the technique of 'rainbow tables' and thus obtaining them in clear text”; “with reference to the 'particular characteristics of the affected individuals', it is noted that the majority of the 18,469 users are professionals registered in professional

registers and/or lists, and do not fall into categories of vulnerable subjects (e.g., victims of violence or abuse, refugees, asylum seekers, etc.) nor minors. Regarding the ease of identifying the affected individuals, it is specified that these are users who, at the time of registration on the website, provide their personal and contact data related to their professional activity (and therefore of a common nature and not particular and/or judicial as per Articles 9-10 of EU Regulation 2016/679), which are published in the online register only if they become member associates, as provided for by Article 7 of the Federprivacy Code of Ethics, as a professional association registered with the MISE (now the Ministry of Enterprises and Made in Italy) pursuant to Law 4/2013. For the aforementioned reasons, the communication to the affected individuals pursuant to Article 34 of the EU Regulation did not concern the entire generality of users/member associates as such, but rather a limited number of 529 individuals whose identity document was exfiltrated. Instead, all 18,469 users experienced potential inconveniences and minor disturbances, as can also be inferred from the small number of requests to exercise rights pursuant to Articles 15 and following of the EU Regulation that our association has received from users/members"; "following the 'defacement' on November 15, 2023, before bringing the Federprivacy site back online, all user/member accounts were cautiously blocked to prevent access by unauthorized individuals. Starting from November 17, 2023, a communication was sent to the 18,469 users/members to inform them of the data breach and the restoration of their account with new credentials to access the reserved area of the Association's website. This communication contained a new password of 12 alphanumeric characters randomly generated by the system, which could be changed by the user with the possibility of setting one of their preference from their account"; "Since the retention of copies of the 529 identity documents was not intentional, but occurred due to a misconfiguration of the application for the quality certificate request form, following the data breach, the anomaly has been corrected [...] Furthermore, since the moment the website was brought back online, the function for requesting the aforementioned quality certificate has been temporarily suspended, and the new procedure no longer requires any identity document requests."

On February 16, 2024, the Office made an additional request for clarification, highlighting how – following a technical assessment carried out by the Office on the data subject to dissemination online and, in particular, on the data of users who, at the time of the breach, were registered on the Association's website – it emerged that the users' passwords were protected with two different cryptographic functions, specifically:

for 4,223 users (with the last access prior to March 3, 2018), the password was stored as a text string composed of 32 hexadecimal characters, followed by the character ":" and 32 alphanumeric characters;

for 15,309 users (with the last access after March 3, 2018), the password was stored as a text string composed of the characters [OMISSIS].

In a note dated February 19, 2024, the Association responded to the aforementioned request for information, stating that:

"the difference between the greater number of records [...] detected during the technical assessment carried out [...] on the data subject to dissemination online and, in particular, on the file named 'flatnews_users.csv', in which the data of 19,532 users were detected, is actually due to the fact that this file contains several hundred registration attempts by 'bot' agents whose accounts were never activated by us, which cannot be classified as 'data subjects', as well as many other cases where the accounts are registered to legal entities, and therefore such information does not constitute 'personal data'. [...] the number of 18,469 data subjects [...] communicated is the result of a [...] careful count of all the real 'natural person' users regularly registered on our website at the time of the hacker attack (S.E. & O.), and not derived from a desire to diminish the severity of the breach";

"in version 1.5 of Joomla used by the Federprivacy website until February 2018, the default password encryption mechanism was used, which consisted of using the MD5 algorithm for hashing passwords. When passwords were created, they were composed of a 32-character salt (the second half of the string after ":") and the first part was the MD5 of the combination of password and salt";

"starting from version XX of Joomla, used by the Federprivacy site from March 2018 onwards, there

was a change of algorithm for greater security, adopting the 'XX' library; since it is impossible to change users' passwords after migration, the only solution adopted is that accounts are automatically migrated to the new version after the first access following the migration, using the new algorithm."

In a note dated March 10, 2024, the Association then provided information on further initiatives taken following the breach of personal data, stating, among other things, that it had carried out the following interventions:

- a) "implementation of password encryption techniques" for all users of the site for whom such security measures had not yet been applied;
- b) "sending communication on 08.03.2024 to all the aforementioned 4,223 users, [...] with which [...] they were notified of the criticality detected in their accounts regarding the cryptographic techniques of the credentials no longer adequate to the current technological progress, with a consequent potential risk to the rights and freedoms of individuals pursuant to Article 34 of EU Regulation 2016/679, and simultaneous communication of the adoption by us of further security measures pursuant to Article 34 paragraph 3 letter b) of the EU Regulation, aimed at preventing the occurrence of such risk, which we implemented by manually intervening to enhance the security level of the credentials, aligning it with the highest standards already applied to all other active users of the site."

In particular, the Association, with the aforementioned communication of March 8, 2024, informed the 4,223 users whose passwords were stored with cryptographic techniques not adequate to the state of the art that:

those who "had not accessed the reserved area for several years, and for this reason had not changed their password for a long time, continued to have by default cryptographic techniques for their credentials no longer adequate to the current technological progress";

"since in this case the more secure cryptographic techniques applied since March 2018 (XX) with the publication of the new site would have been activated automatically only at the time of [...] the first login, but in the meantime there was a high potential risk for the [...] rights and freedoms pursuant to Article 34 of the GDPR, in addition to [...] notifying] this, [...] the Association has] taken further security measures aimed at preventing the occurrence of such risk, manually intervening to enhance the security level of the [...] credentials and align it with the highest standards." already applied to the rest of all other active users."

With a subsequent note dated March 27, 2024, the Association informed the Authority that it had implemented the following initiatives:

- implementation of additional security measures to protect against cyber attacks;
- sending further communication "on March 26, 2024, to all 4,223 users of our site who, following the migration from Joomla 1.5 that took place in March 2018, had maintained the previous mechanism based on MD5 for hashing passwords with a 32-character salt, to provide them with practical advice to mitigate the possible negative effects arising from the exposure of their passwords";
- "making available to all the aforementioned 4,223 users a complimentary coupon code worth €102 each valid for 1 year of free membership fee as a member of Federprivacy, in light of the potential inconveniences of the breach that affected them."

With the aforementioned communication of March 26 – sent, ultimately, to the 4,223 users whose passwords were stored using cryptographic techniques not up to date – in particular, the Association highlighted that "considering that following the aforementioned data breach the confidentiality of the passwords previously used by users was compromised, and even though we subsequently intervened to generate new credentials and implement cryptographic techniques to strengthen the level of security, to mitigate the possible negative effects of the breach [...] we still recommend not to use the [...] previous password on other websites/social networks/apps/etc., because malicious actors may have become aware of it and use it to attempt to fraudulently access other [...] accounts. Furthermore, on all websites/social networks/apps/etc. that allow it, it is always advisable to enable two-factor authentication (e.g., OTP) to ensure greater security of personal data, especially if it involves sensitive information concerning you."

3. Notification of breaches and defensive memoranda.

With a note dated May 30, 2024, following the examination of the elements acquired during the

investigation and the subsequent evaluations of the Authority, based on the findings of the technical report from the Office dated May 12, 2024, the Association was accused of having engaged in conduct not compliant with the regulations regarding the protection of personal data and, in particular, that, considering the technical measures applied to the personal data subject to the breach, as well as the risks to the rights and freedoms of individuals arising from the data breach that occurred, Federprivacy had not promptly sent a comprehensive communication to the affected parties. It was also noted that the Association had not conducted itself in accordance with the data protection regulations concerning security obligations and the principles of integrity and confidentiality and data retention limitation.

Article 34 of the Regulation states, in fact, that “when a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate the breach to the data subject without undue delay” (par. 1), that “the communication to the data subject [...] shall describe in clear and plain language the nature of the personal data breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, letters b), c) and d)” (par. 2) and that such communication is not required, in particular, if “the data controller has implemented appropriate technical and organizational measures to protect and such measures were applied to the personal data subject to the breach, in particular those intended to render personal data unintelligible to any person not authorized to access it, such as encryption” (par. 3, lett. a)).

The Regulation further indicates that, in assessing the risk, both the likelihood and the severity of the risks to the rights and freedoms of data subjects should be taken into account and that such risks should be determined based on an objective assessment (cf. cons. nn. 75 and 76).

In this regard, the “Guidelines 9/2022 on the notification of personal data breaches under the GDPR” adopted by the European Data Protection Board on March 28, 2023 (hereinafter “Notification Guidelines”) identify the following factors to consider – in the event of a personal data breach – in assessing the risk to the rights and freedoms of data subjects: the type of breach; the nature, sensitive character, and volume of personal data; the ease of identification of the data subjects; the severity of the consequences for the data subjects; the particular characteristics of the data subject; the particular characteristics of the data controller; as well as the number of data subjects involved.

The same document also specifies that “the Regulation states that the communication of a breach to data subjects should occur ‘without undue delay’ which means as soon as possible,” considering that the main objective of the communication to data subjects is to provide them with specific information about the measures they can take to protect themselves, as well as that the data controller, among the measures to be taken to remedy the breach and mitigate its possible negative effects for the data subjects, “should also provide specific advice to individuals on how to protect themselves from the possible consequences.

negative of the violation.”

It should also be taken into account the principles established regarding the protection of personal data, according to which they must be “processed in a manner that ensures an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage (‘integrity and confidentiality’)” (art. 5, par. 1, lett. f), of the Regulation), to be read in conjunction with art. 32 of the Regulation, according to which, in terms of processing security, “taking into account the state of the art and the costs of implementation, as well as the nature, scope, context and purposes of the processing, and the risk of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the data processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk [...]” (par. 1) and “in assessing the appropriate level of security, particular consideration shall be given to the risks presented by the processing which are specifically due to the destruction, loss, alteration, unauthorized disclosure or access, whether accidental or unlawful, to personal data transmitted, stored or otherwise processed” (par. 2).

Art. 5, par. 1, lett. e), of the Regulation further establishes that personal data must be “kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed [...]” (‘storage limitation’).

On June 27, 2024, the Association submitted its defense writings and on that occasion highlighted that:

with reference to art. 83, par. 2, lett. a), of the Regulation, “the hacker attack did not primarily aim to obtain profit by the criminals, who moreover never made any economic claims nor put the data up for sale, but rather the intention of these was to discredit the good name of Federprivacy, harm its reputation, and cause it economic damage, [...] highlighting a conduct of a mafia-like nature by the subject who commissioned the ‘Alpha Team’ group to carry out the hacker attack [...] also publishing online the exfiltrated data on November 28, 2023, in conjunction with the ‘Cyber & Privacy Forum’ event promoted by Federprivacy and held on November 29, 2023” (see note of June 27, 2024 cited, p. 1);

with reference to art. 83, par. 2, lett. b), of the Regulation, “Considering the size of the association and the non-profit activity it carries out with barely sufficient economic resources to meet its statutory educational/informative/etc. purposes [...] we believe that the contested violations can be attributed to mere negligent conduct” (see cited note, p. 2);

with reference to art. 83, par. 2, lett. c), of the Regulation: “following the hacker attack on November 13, 2023, all accounts were immediately blocked, and at the time of the website going back online, which occurred on November 17, 2023, a first communication was sent to all affected individuals, providing new credentials to access the reserved area. Subsequently, following the publication of the identity documents exfiltrated by the hackers, which occurred on December 3, 2023, a communication was sent to the affected individuals pursuant to art. 34 of the R[egulation], specifying that the breach could “represent a high risk to the rights and freedoms of the data subject (such as identity theft).” Following the certified email received from the Authority late on Friday, February 16, 2024 (at 21:27), we promptly activated to analyze the document “Guidelines for Cryptographic Functions for Password Storage” dated December 7, 2023 provided to us [...] by the Office of the Guarantor, in order to respond within the 5 days set by it. After the initial study activities of the aforementioned document, on March 8, 2024, we sent a further communication pursuant to art. 34 of the Regulation to the 4,223 users on whom the Authority had identified the inadequacy of the state of the art of password encryption, highlighting this criticality to the affected individuals, and informing them of the risks to their rights and freedoms, communicating to them the additional security measures we adopted through the manual implementation of credential encryption to align them with the highest standards. Meanwhile, continuing with the analysis activities, and utilizing the specialized support of external professionals capable of providing the required consultancy due to the high technical complexity of the issue raised by the Authority, we adopted further security measures to ensure the robustness of the passwords and made periodic changes mandatory, and on March 26, 2024, we sent the affected individuals further information and advice to mitigate the risks and alleviate the effects of the breach. Considering the complexity of the relationships provided [...] by the Office of the Guarantor, we believe we have done everything possible to progressively implement all necessary measures, keeping the affected individuals updated “step by step.” (see cited note, p. 2);

with reference to art. 83 par. 2 lett. d) of the Regulation: “For its website, Federprivacy uses the CMS Joomla [OMISSIS] provided by developers as a platform that integrates the principles of data protection ‘by design’ and data protection ‘by default’ prescribed by the GDPR. As a web provider, we have identified Aruba Business with the

****Professional Hosting Service "Cloud Managed" in Dedicated Cloud Infrastructure in Data Center Certified Rating 4, ISO 9001:2008 and ISO 27001:2013.****

The system is equipped with daily incremental backups with 14 restore points and autonomous restore from the control panel, as well as integrated antispam via Cloudmark Gateway and integrated AntiVirus ClamAV. Furthermore, the site is equipped with a specific Firewall for Joomla called "RSFirewall!", [OMISSIS]. To ensure the confidentiality of users' and associates' personal data, the management of Aruba's services is carried out directly and exclusively by Nicola Bernardi Malatesta, president and legal representative of the association. Following the aforementioned hacker attack, utilizing the services of OneFirewall Alliance LTD, a company specialized in the field of cybersecurity, our association has further strengthened security measures [OMISSIS] (see cited note, pp. 3 and 4); with reference to Article 83, paragraph 2, letter f), of the Regulation, "Without prejudice to what has been previously expressed regarding the size of the association's structure, we believe we have offered maximum cooperation to the Authority from the beginning and at every subsequent moment,

fulfilling the required obligations and responding promptly and within the indicated timeframes to various requests for information, implementing both the suggestions and indications provided by your [...Office], as well as keeping the Authority updated on the activities we subsequently undertook proactively" (see cited note, p. 4);

with reference to Article 83, paragraph 2, letter g), of the Regulation, "The categories of data subjects involved concern adult professionals (lawyers/accountants/consultants/DPO/etc.) for whom only common data related exclusively to their professional activities, which do not concern their private sphere, are processed. Therefore, the association does not process data of minors and/or other vulnerable subjects, and generally does not intentionally process special categories of data as per Article 9 of the Regulation" (see cited note, p. 4);

with reference to Article 83, paragraph 2, letter h), of the Regulation, "The breach was duly reported preliminarily to the Authority within 72 hours from the moment we became aware of the hacker attack as required by the Regulation, and was subsequently supplemented with details" (see cited note, p. 4);

with reference to Article 83, paragraph 2, letter i), of the Regulation, "Our association has not been the recipient of previous corrective measures concerning the specific violation contested" (see cited note, p. 4);

with reference to Article 83, paragraph 2, letter j), of the Regulation, "At present, our association does not adhere to specific codes of conduct pursuant to Article 40 of the Regulation, and does not possess certifications pursuant to Article 42 of the R[egulation]" (see cited note, p. 4);

with reference to Article 83, paragraph 2, letter k), of the Regulation, "In the risk analyses conducted in previous years, potential traditional cyber attacks (virus/malware/ransomware/phishing/etc.) had always been contemplated, but considering the nature of the non-profit activity carried out by the association, as well as the data processed by it (generally not of significant interest in the world of cybercrime and not even sensitive under Article 9 of the Regulation), it had never been deemed predictable or even conceivable that an attack with purely criminal purposes aimed solely at damaging our association would occur, especially if carried out with such a level of brutality and capable of undermining the technical and organizational security measures that we deemed adequate for our reality, in which we had also included the designation of a Data Protection Officer (DPO), although we were not subject to the obligation set forth by Article 37 of the Regulation. Only retrospectively, we were able to acknowledge such eventualities, modifying our risk-based approach and also including potential criminal attacks merely aimed at damaging our association" (see cited note, p. 5).

****4. Outcome of the Procedure****

As a result of the examination of the elements acquired during the investigation and the subsequent evaluations of the Authority, based on the findings of the specific technical reports prepared during the procedure and the aforementioned defensive memoranda, it has emerged that the Association has engaged in conduct that is not compliant with the regulations regarding the protection of personal data. In this context, confirming the observations notified by the Office with the note of May 13, 2024, it emerges that, in the case at hand, Federprivacy has engaged in three distinct conducts in violation of the regulations regarding the protection of personal data:

1. The first, relating to the late communication of the data breach to the affected individuals, in violation of Article 34 of the Regulation;
2. The second, relating to the failure to adopt adequate measures to protect users' passwords, in violation of Articles 5, paragraph 1, letter f), and 32 of the Regulation;
3. The third, relating to the retention of identity documents of associated professionals, in violation of Article 5, paragraph 1, letter e), of the Regulation.

****4.1. The Delay in Communicating the Personal Data Breach to the Affected Individuals.****

During the investigation, it emerged that the data breach in question involved, among the other, the following different types of personal data:

copies of identity documents of 529 associated professionals who had requested the quality certificate issued by the Association, pursuant to Law No. 4 of January 14, 2013;
the authentication credentials (username, consisting of an email address, and password, in the form of a text string, also known as a digest) of 18,469 users registered on the Association's website.

With reference, in particular, to the violation of the second type of personal data, it is necessary to consider that the assessment of the risk to the rights and freedoms of individuals resulting from the same violation must be carried out taking into account, in particular, the following factors:

- the nature of the personal data breach, which occurred as part of a cyber attack aimed at acquiring personal data – including the authentication credentials of 18,469 individuals – and subsequently disseminating them online;
- the severity and persistence of the possible consequences that could arise for the individuals from the unlawful use of the compromised authentication credentials resulting from the breach (e.g., to illegally access computer systems or online services and consult or acquire other personal data of the individuals; this also considering the habit of users to use, even after some time, the same passwords or similar passwords);
- the large number of individuals to whom the authentication credentials in question refer and the ease with which specific individuals can be identified directly from the personal data subject to the breach;
- the level of security guaranteed by the cryptographic functions used to protect the passwords of users stored in the systems of the data controller, in terms of resistance to the most common cyber attacks (e.g., brute force or dictionary attacks) aimed at identifying the password that generated a specific digest.

In relation to this last factor – to be assessed also in light of the indications and recommendations provided by the Authority with the guidelines on password storage prepared in collaboration with the National Cybersecurity Agency (provision No. 594 of December 7, 2023, web doc No. 9962283) – it should also be considered that:

- the “Guidelines 01/2021 on examples concerning the notification of a personal data breach” (adopted by the European Data Protection Board on December 14, 2021), in relation to a personal data breach involving user passwords (see case No. 06), remind that, even in the case of password storage using state-of-the-art cryptographic techniques, communication, although not mandatory, can be considered a good practice;
- with regard to users registered on the Association’s website who last accessed after March 3, 2018, the cryptographic function used to store their passwords (the password hashing algorithm “bcrypt”, with the application of a 128-bit salt and a computational cost of 10), although not listed in the aforementioned guidelines on password storage among the recommended algorithms, can currently be considered adequate to ensure an appropriate level of security; therefore, it is believed that, for this group of individuals, the condition referred to in Article 34, paragraph 3, letter a), of the Regulation is satisfied, for which communication to the individuals is not required;
- with reference, instead, to users registered on the Association’s website who last accessed before March 3, 2018 (the date from which the methods of password storage were modified), the cryptographic function used to store their passwords (the “MD5” hashing function, with the application of a 128-bit salt) is not deemed adequate to ensure an appropriate level of security, due to the multiple and well-known vulnerabilities of such function; therefore, it is believed that, for this group of individuals, the personal data breach is likely to present a high risk, a circumstance for which communication to the individuals is required pursuant to Article 34 of the Regulation.

Initially, the Association did not therefore carry out a correct assessment regarding the risks arising from the breach of the authentication credentials of users registered on its website and believed that the breach, as a whole, was not likely to present a high risk to the rights and freedoms of individuals. Following the requests for information made by the Authority – also aimed at stimulating a correct assessment of the risks arising from the breach of such types of data – the Association initially continued to assert that “all 18,469 users have suffered potential inconveniences and minor annoyances” (see note of February 11, 2024, p. 2) and, only at a later stage, proceeded to send a “communication on March 8, 2024, to all the aforementioned 4,223 users, [...] with which [...] they were informed of the criticality identified in their accounts regarding cryptographic techniques of credentials no longer adequate to current technological progress with consequent potential risk for the rights and freedoms of individuals pursuant to Article 34 of EU Regulation 2016/679” (see note of March 10, 2024, p. 1) and then “further communication on March 26, 2024, to all 4,223 users [...] to provide

their practical advice to mitigate the possible negative effects resulting from the exposure of their passwords” (see note of March 27, 2024, p. 1).

During the investigation, it emerged that the Association only fulfilled its informational obligations towards users registered on the Association's website, whose passwords were stored using cryptographic techniques not up to the state of the art, on March 26, 2024. In fact, the previous communications sent by the Association – both the one transmitted starting from November 17, 2023, to all users registered on its website in order to “inform them of the data breach and the restoration of their account with new credentials to access the reserved area of the Association's website,” and the one sent on March 8, 2024, to the only 4,223 users whose passwords were stored using cryptographic techniques not up to the state of the art – did not contain all the information required by Article 34, paragraph 2 of the Regulation (in particular with reference to those mentioned in letter c) of Article 33, paragraph 3, of the Regulation).

In particular, for the reasons stated above, the aforementioned communications did not allow the affected individuals to be aware of the risks arising from the breach and consequently did not enable them to take timely necessary precautions, undermining the very function of the communication of the occurrence of the breach to the affected individual, as provided for by Article 34, paragraph 2, of the Regulation.

Nor, in the presence of the specific regulatory obligations cited, can the assertion that the Association incurred this delay because it took time to delve into the requests of the Guarantor, as well as the documents cited in support of them (including the “Guidelines for Cryptographic Functions for Password Storage,” adopted by the Authority with the aforementioned provision of December 7, 2023), be relevant, believing “to have done everything possible to progressively implement all necessary measures, and keeping the affected individuals updated ‘step by step’” (see defensive writings of June 27, 2024, p. 2).

In light of the above, there are grounds for a violation by the Association of the obligations set forth in Article 34, paragraph 2, of the Regulation concerning the late communication of the personal data breach to the users registered on the Association's website whose passwords were stored using cryptographic techniques not up to the state of the art.

4.2. The failure to adopt adequate security measures and the violation of the principle of integrity and security.

With reference to the aspects related to the security of processing, it emerged during the investigation that, at the time the personal data breach occurred, the passwords of 4,223 users were stored in the systems used by the Association in the form of a digest calculated using the “MD5” hashing function, after applying a 128-bit salt.

The cited hashing function is not robust, in cryptographic terms, and its use does not therefore represent an effective measure to protect users' passwords, as serious vulnerabilities of this function have been known for several years that allow one to derive the password that generated a digest.

In this regard, it is noted that storage using state-of-the-art cryptographic techniques is one of the commonly adopted measures to protect the passwords of users of a computer system or online service; this is due to the high risks in the event of unauthorized access to or disclosure of the same, due to users' habit of using, even after a long time, the same passwords or similar passwords for the same or other computer systems or online services.

The use of cryptographic techniques not up to the state of the art for the storage of users' passwords therefore contradicts Article 5, paragraph 1, letter f), and Article 32, paragraph 1, letter a), of the Regulation, which expressly identifies encryption as one of the possible measures suitable to ensure a level of security appropriate to the risk (see also recital 83 of the Regulation, in the part where it states that “the data controller [...] should assess the risks inherent in the processing and implement measures to mitigate those risks, such as encryption”).

In light of the above, there are grounds for a violation by the Association of the principle of integrity and confidentiality set forth in Article 5, paragraph 1, letter f), of the Regulation, as well as of the obligations regarding the security of processing set forth in Article 32 of the Regulation.

4.3. The violation of the principle of data retention limitation.

Regarding the principle of data retention limitation, it emerged during the investigation that – “due to a misconfiguration of the application of the request form for the quality certificate” issued by the Association pursuant to Law No. 4 of January 14, 2013 – copies of the identity documents of 529 associated professionals were stored within the systems subject to the breach.

In this regard, it is noted that the storage of personal data must be carried out for the time strictly necessary to achieve the purposes for which such data were collected (Article 5, paragraph 1, letter e), of the Regulation).

With reference to the specific case, it is observed that the access to or unlawful disclosure of the data...

identity documents poses a high risk to the rights of the data subjects, considering the possibility that their knowledge may facilitate identity theft. The retention of identity documents for a period longer than strictly necessary for the purposes for which they are processed, determined by an incorrect configuration of the processing systems used by the data controller, is therefore in contrast with Article 5, paragraph 1, letter e), of the Regulation. In light of the above, there are grounds for a violation by the Association of the principle of data retention limitation as per Article 5, paragraph 1, letter e), of the Regulation.

5. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to Article 58, paragraph 2, of the Regulation. In light of the overall findings, the Authority believes that the statements, documentation, and reconstructions provided by the data controller during the investigation do not allow for overcoming the objections notified by the Office with the initiation of the proceedings and are therefore unsuitable to order the closure of the present proceedings, as none of the cases provided for in Article 11 of the Garante Regulation No. 1/2019 apply. The processing of personal data carried out by Federprivacy is indeed unlawful, as stated above, since it was carried out in violation of Articles 5, paragraph 1, letters e) and f), 32, and 34 of the Regulation.

Regarding the exercise of corrective powers under Article 58, paragraph 2, of the Regulation, it is noted that the Association, during the proceedings, has adopted technical measures aimed at bringing the processing subject to this proceeding into compliance with the Regulation, adopting further security measures to prevent the recurrence of similar situations. In this context, therefore, considering that specific measures have been adopted to ensure that the processing in question complies with the current regulations on personal data protection, the conditions for the adoption of corrective measures under Article 58, paragraph 2, of the Regulation are not currently met.

6. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code). The Garante, pursuant to Article 58, paragraph 2, letter i), of the Regulation and Article 166 of the Code, has the power to impose an administrative pecuniary sanction provided for in Article 83, paragraph 5, of the Regulation, by adopting an injunction order (Article 18 of Law No. 689 of November 24, 1981), in relation to the processing of personal data subject to the data breach, which has been found to be unlawful, as stated above.

With reference to the elements listed in Article 83, paragraph 2, of the Regulation for the purpose of applying the administrative pecuniary sanction and its quantification, considering that the sanction must be “effective, proportionate, and dissuasive in each individual case” (Article 83, paragraph 1 of the Regulation), it is represented that, in this case, the following circumstances have been taken into account: regarding the conduct related to the late communication of the data breach to the affected data subjects, the significant number of data subjects whose personal data were, in some cases, involved in the breach (4,223) has been considered relevant in relation to the severity of the violation.

The duration of the violation has also been deemed significant, noting that, since the use of non-state-of-the-art cryptographic techniques for the storage of user passwords became known (if not already from November 15, at least from December 5, 2023—the date of sending the supplementary notification of the personal data breach), the Association, over three months later (March 26, 2024), finally communicated to the affected data subjects pursuant to Article 34 of the Regulation; regarding the second conduct concerning the failure to adopt adequate measures to protect user passwords, the nature of the violation has been considered, as it involved, among other things, cases punished more severely under Article 83, paragraph 5, of the Regulation (general principles of processing, particularly the principle of integrity and confidentiality); with reference to the third conduct related to the retention of identity documents of associated professionals, the relationship between the type of data involved and the nature of the violation has been examined (specific risk of unlawful acts such as identity theft resulting from the online dissemination of a copy of the identity document for 529 affected individuals), the nature of the violation involved, among other things, cases punished more severely under Article 83, paragraph 5, of the Regulation (general principles of processing, particularly the principle of data retention limitation), as well as the circumstance that this violation occurred due to “a technical configuration error,” which was promptly addressed by the Association; for all conducts, the degree of responsibility of the data controller or processor has been considered, taking into account the technical measures implemented pursuant to Articles 25 and 32 of the Regulation, which were specifically highlighted in the proceedings, and the decision to update the...

****systems and to further implement security measures by utilizing the consultancy of a specialized company in the field of cybersecurity, the fact that the data controller has notified the Authority of the personal data breach within the prescribed terms, as well as the absence of previous relevant violations committed by the data controller.****

It is also considered that the economic conditions of the offender, determined by a significant operational loss, as well as the nature of a non-profit association, are relevant in this case, in light of the aforementioned principles of effectiveness, proportionality, and deterrence to which the Authority must adhere in determining the amount of the sanction (art. 83, par. 1, of the Regulation).

In light of the above elements and the assessments made, it is deemed appropriate, in this specific case, to apply an administrative sanction against the association Federprivacy in the amount of €6,000 (six thousand), in relation to the totality of the previously described violations (violation of art. 34 of the Regulation, violation of arts. 5, par. 1, lett. f), and 32 of the Regulation, violation of art. 5, par. 1, lett. e), of the Regulation).

In this context, considering the type of violations established that resulted in the acquisition and subsequent dissemination online, by third parties, of personal data relating to a large number of data subjects, it is also considered that, pursuant to art. 166, par. 7, of the Code and art. 16, par. 1, of the Garante Regulation no. 1/2019, the publication of this section, containing the injunction order, on the Garante's website should be carried out.

****ALL OF THE ABOVE CONSIDERED, THE GUARANTEE****

declares, pursuant to arts. 57, par. 1, lett. f), and 83 of the Regulation, the unlawfulness of the processing carried out by the association Federprivacy (C.F. 94156260484 - P.I. 06413480481), based in Figline e Incisa Valdarno (FI), via degli Innocenti 2, as stated in the reasoning, for the violation of arts. 5, par. 1, lett. e) and f), 32 and 34 of the Regulation;

****ORDERS****

the association Federprivacy, pursuant to art. 58, par. 2, lett. i), of the Regulation, to pay the sum of €6,000 (six thousand) as an administrative pecuniary sanction for the violations indicated in this provision;

****COMMANDS****

therefore the same Association to pay the aforementioned sum of €6,000 (six thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts pursuant to art. 27 of law no. 689/1981. It is reminded

that the offender retains the option to settle the dispute by paying – always according to the methods indicated in the annex – an amount equal to half of the imposed sanction, within the term provided for the submission of the appeal as indicated below (art. 166, par. 8, of the Code);

****DISPOSES****

pursuant to art. 166, par. 7, of the Code and art. 16, par. 1, of the Garante Regulation no. 1/2019, the publication of the injunction order on the Garante's website;

pursuant to art. 154-bis, par. 3, of the Code and art. 37 of the Garante Regulation no. 1/2019, the publication of this provision on the Authority's website;

pursuant to art. 17 of the Garante Regulation no. 1/2019, the annotation of the violations and the measures adopted in accordance with art. 58, par. 2 of the Regulation, in the internal register of the Authority provided for by art. 57, par. 1, lett. u) of the Regulation.

Pursuant to art. 78 of the Regulation, arts. 152 of the Code and 10 of Legislative Decree 150/2011, an appeal against this provision may be submitted to the ordinary judicial authority, with an application filed at the ordinary court of the place indicated in the same art. 10, within 30 days from the date of communication of this provision, or 60 days if the appellant resides abroad.

Rome, November 13, 2024

****THE PRESIDENT****

Stanzione

****THE REPORTER****

Ghiglia

****THE SECRETARY GENERAL****

Mattei